Microsoft Entra Conditional Access V2 Policy Plans for the CA Policy Framework

Mapping the 26 Framework Policies to Policy Plans

Summary

The CA Policy Framework is published on GitHub as AzFrameworks/CAPolicyFramework. It deploys 26 Microsoft Entra Conditional Access policies. The script Import-CAPolicyFrameworkV2.ps1 (version 2.2) performs the deployment. The policies fall into three families. The 12 BAS policies form the baseline. The 4 DLP policies protect data in classified applications. The 10 PER policies cover privileged, guest, workload and agent scenarios. Every policy is created in Report-only mode (enabledForReportingButNotEnforced). In this mode, a policy is evaluated and logged but not enforced. All names follow one pattern: <Family>-<Number>-2606-<Action>-<Resources>-<Users>-<Purpose>.

This document maps every framework policy one-to-one to a rule in a Conditional Access V2 policy plan. There are seven plans. No policy is merged, removed or changed in intent. In total, 26 V1 policies become 26 V2 rules in 7 plans. Scope that is identical for every rule in a plan moves into the plan's shared conditions. Everything else stays on the individual rule.

A companion PowerShell script, Import-CAPolicyFrameworkV2-PolicyPlans.ps1, creates the plans and their rules in the tenant. It builds the same 26 policies as V2 rules. This lets you compare the V2 result directly with the V1 deployment.

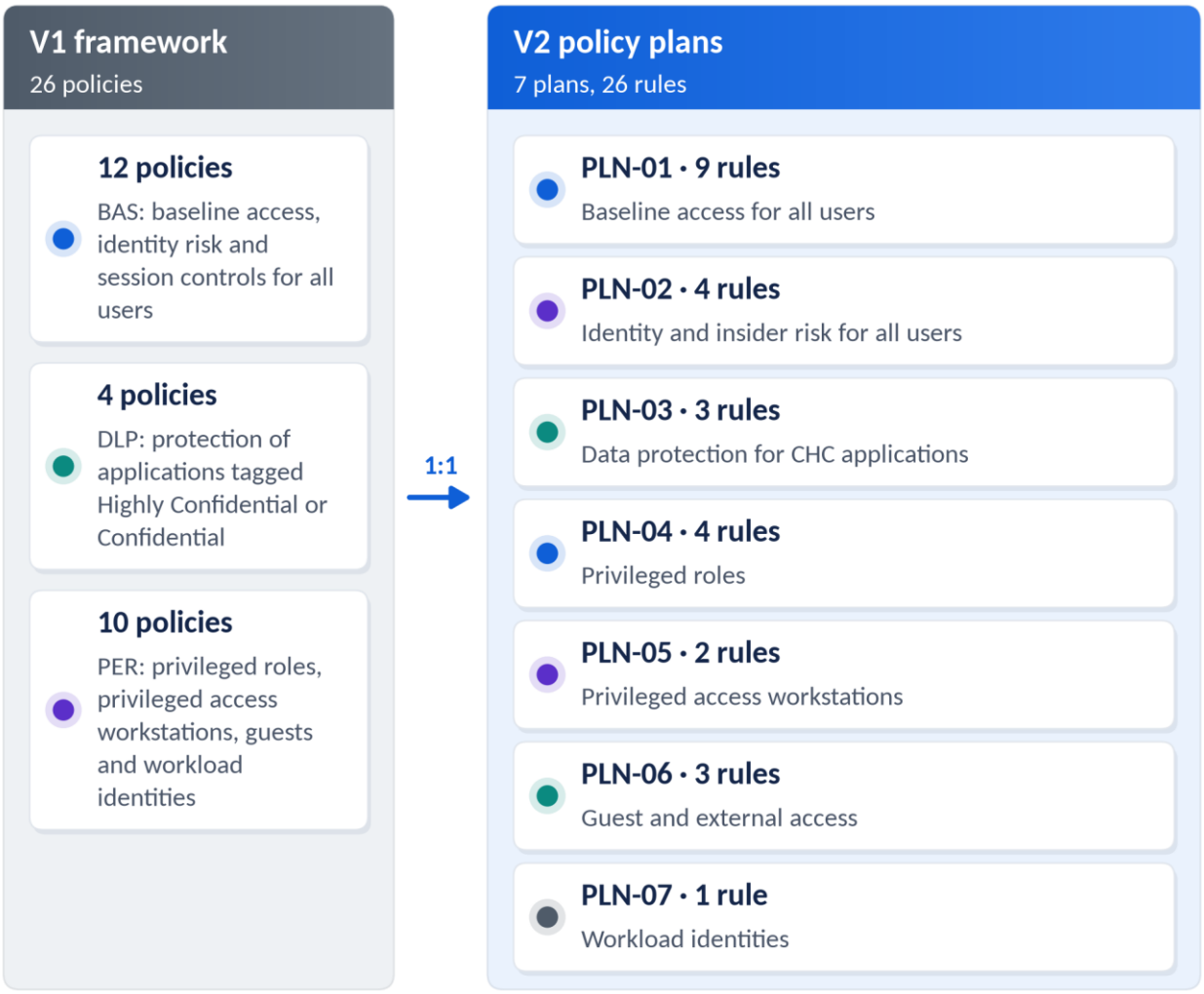


Figure 1: The 26 framework policies map one-to-one to 26 rules in seven policy plans. The V1 families (BAS, DLP, PER) are regrouped by audience and protection goal; no policy is consolidated.

Conditional Access V2 Policy Plans

A policy plan groups related rules under one object. A plan carries a displayName, a description, owners, tags, sharedConditions and its rules; at least one rule is required when a plan is created. The version and templateId properties are read-only.

Each rule has its own displayName, description and state (enabled, disabled or enabledForReportingButNotEnforced), together with its own conditions and controls, which comprise grant controls and session controls.

Rules inherit the plan's shared conditions and can add further conditions, but they cannot remove an inclusion or exclusion defined at plan level. In effect, a rule applies to the intersection of the plan scope and the rule scope.

Classic V1 policies and V2 rules are evaluated together. There is no priority order between them, so all applicable requirements accumulate.

Policy plans are managed through Microsoft Graph beta at /identity/conditionalAccess/plans, with rules under /plans/{id}/rules. The required permission is Policy.ReadWrite.ConditionalAccess, and the least-privileged role is Conditional Access Administrator. Beta APIs are subject to change and are not supported for production use.

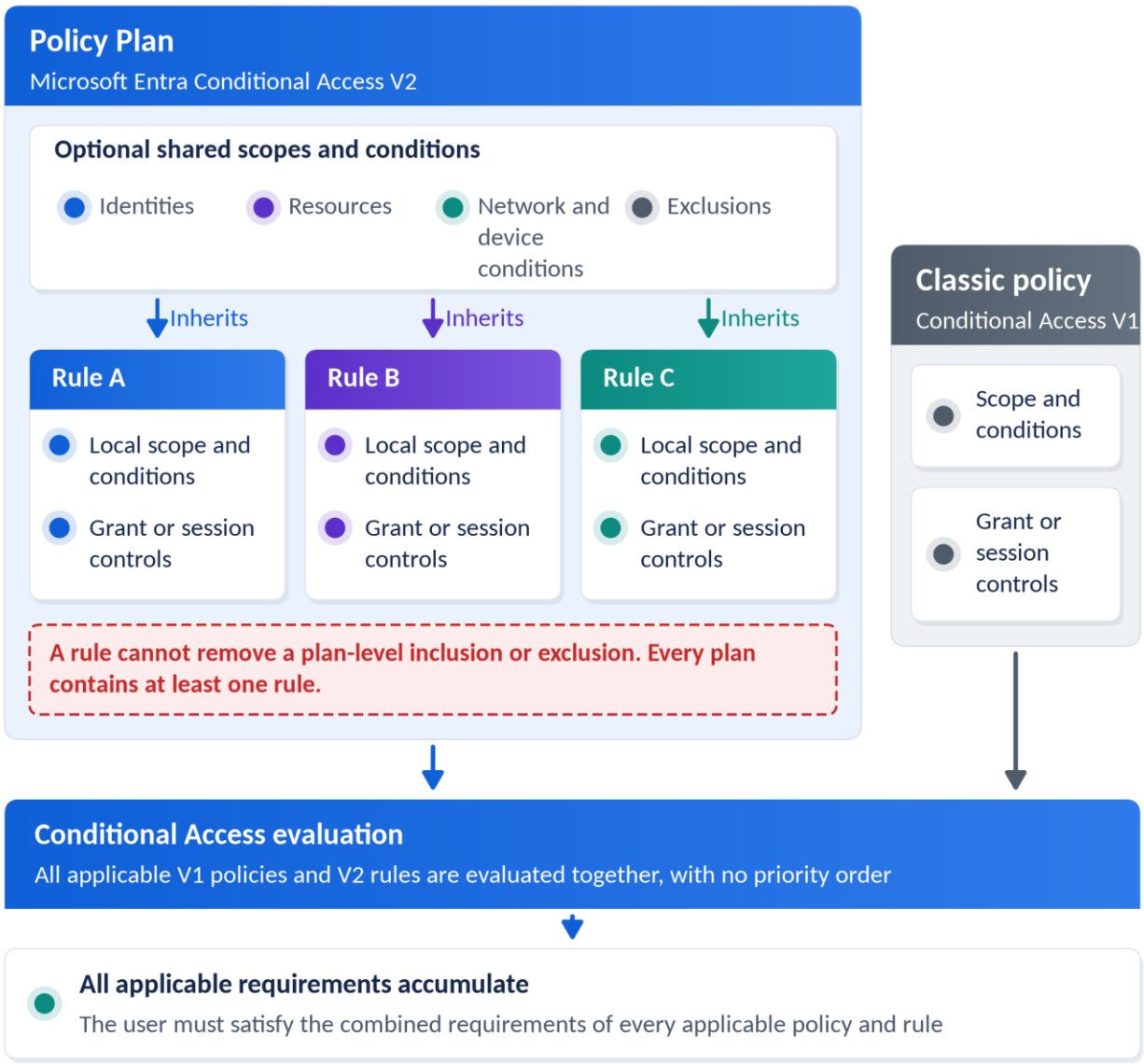


Figure 2: Policy plan model. Shared scopes and conditions are defined once on the plan and inherited by every rule; each rule adds its own scope and its grant or session controls. Classic V1 policies and V2 rules are evaluated together.

Plan Design Principles

The plan design follows five principles that keep the V2 result directly comparable with the V1 framework.

- No consolidation. Each framework policy becomes exactly one rule with the same name as the V1 policy and the same conditions, grant controls and session controls, so Report-only results can be compared directly.
- Grouping by audience and protection goal. Plans cover all users, risk signals, classified applications, privileged roles, privileged access workstations, guests and external users, and workload identities.
- Shared conditions hold only what every rule in a plan has in common. For user plans this is always the break-glass exclusion and the user population; for PLN-03 it also includes the application filter.
- Local exclusions stay on the rule. A rule cannot remove plan scope but can add exclusions, so BAS-002 excludes the Directory Synchronization Accounts role, BAS-007 and BAS-011 exclude guests, and BAS-011 also excludes the Global Administrator role.
- Rules start in Report-only, as in the V1 framework. Plans are named PLN-01-2606-… to PLN-07-2606-…, and rules keep their V1 names.

Plan Overview

The seven plans and their shared conditions are summarized below. Together they contain 26 rules, one for each framework policy.

Plan	Rules	Shared Conditions	Purpose
PLN-01-2606-Baseline-AllUsers	9	All users; excludes break-glass accounts	Baseline access and session controls for every user
PLN-02-2606-IdentityAndInsiderRisk-AllUsers	4	All users; excludes break-glass accounts	Responses to sign-in, user, insider and agent risk
PLN-03-2606-DataProtection-CHCApplications	3	All users; excludes break-glass accounts; applications whose custom security attribute DataSensitivity.Classification is "Highly Confidential" or "Confidential"	Stronger controls for classified applications
PLN-04-2606-PrivilegedRoles	4	42 privileged directory roles; excludes break-glass accounts	Location, risk and device controls for administrators

Plan	Rules	Shared Conditions	Purpose
PLN-05-2606-PrivilegedAccessWorkstations	2	42 privileged roles plus the secure workstation group (PAW-Global-Users); all applications; excludes break-glass accounts	Phishing-resistant MFA and PAW devices for administrators
PLN-06-2606-GuestAndExternalAccess	3	Guests and external users; excludes break-glass accounts	Limits for guests and external users
PLN-07-2606-WorkloadIdentities	1	Service principals owned by the tenant	Risk-based block for workload identities
Total	26		

Plan-by-Plan Detail

Each subsection introduces a plan, shows its structure and lists its rules. The local conditions column shows only what the rule adds to the plan scope.

PLN-01 Baseline Access for All Users

PLN-01-2606-Baseline-AllUsers holds the nine baseline rules that apply to every user. The plan carries the shared user scope and the break-glass exclusion, while guest and role exclusions remain on the individual rules that need them.



Figure 3a: PLN-01 Baseline access: nine rules for all users. The plan holds the shared user scope and break-glass exclusion; guest and role exclusions stay on the individual rules.

Rule	Local Conditions (in Addition to Plan Scope)	Controls
BAS-001-2606-Block-AllResources-AllUsers-LegacyAuth	All resources; client apps Exchange ActiveSync and other clients	Block
BAS-002-2606-Allow-AllResources-AllUsers-RequireMFA	All resources; excludes Directory Synchronization Accounts role	Require MFA
BAS-003-2606-Block-AllResources-AllUsers-UnsupportedPlatform	All resources; all platforms except Android, iOS, Windows	Block

Rule	Local Conditions (in Addition to Plan Scope)	Controls
	Phone, Windows, macOS, Linux	
BAS-004-2606-Allow-AllResources-AllUsers-NoPersistentBrowser	All resources; device filter: devices not hybrid-joined or not compliant	Session: persistent browser never; sign-in frequency 1 hour
BAS-007-2606-Block-AllResources-AllUsers-RequireCompliantDevice	All resources; excludes guests and external users; device filter excludes compliant devices	Block
BAS-008-2606-Block-AllResources-AllUsers-DeviceFlowAuthenticationTransfer	All resources; authentication flows: device code flow and authentication transfer	Block
BAS-010-2606-Allow-O365-AllUsers-ApplicationEnforcedRestrictions	Office 365; all client apps	Session: application-enforced restrictions
BAS-011-2606-Allow-AllResources-AllUsers-SecureSecurityInfoRegistration	User action: register security information; all locations except trusted; excludes guests and Global Administrator role	Require MFA
BAS-012-2606-Allow-O365Apps-AllUsers-ApplicationEnforcedRestrictions	Office 365	Require MFA; session: application-enforced restrictions

PLN-02 Identity and Insider Risk

PLN-02-2606-IdentityAndInsiderRisk-AllUsers groups the four rules that respond to risk signals: sign-in risk, user risk, insider risk from Microsoft Purview Adaptive Protection, and risk for agent users. All users are in scope, with break-glass accounts excluded at plan level.

PLN-03 Data Protection for CHC Applications

PLN-03-2606-DataProtection-CHCApplications applies stronger controls to classified applications. In addition to all users and the break-glass exclusion, the plan shares the application filter for applications whose custom security attribute DataSensitivity.Classification is "Highly Confidential" or "Confidential", so every rule in the plan targets the same set of classified applications.

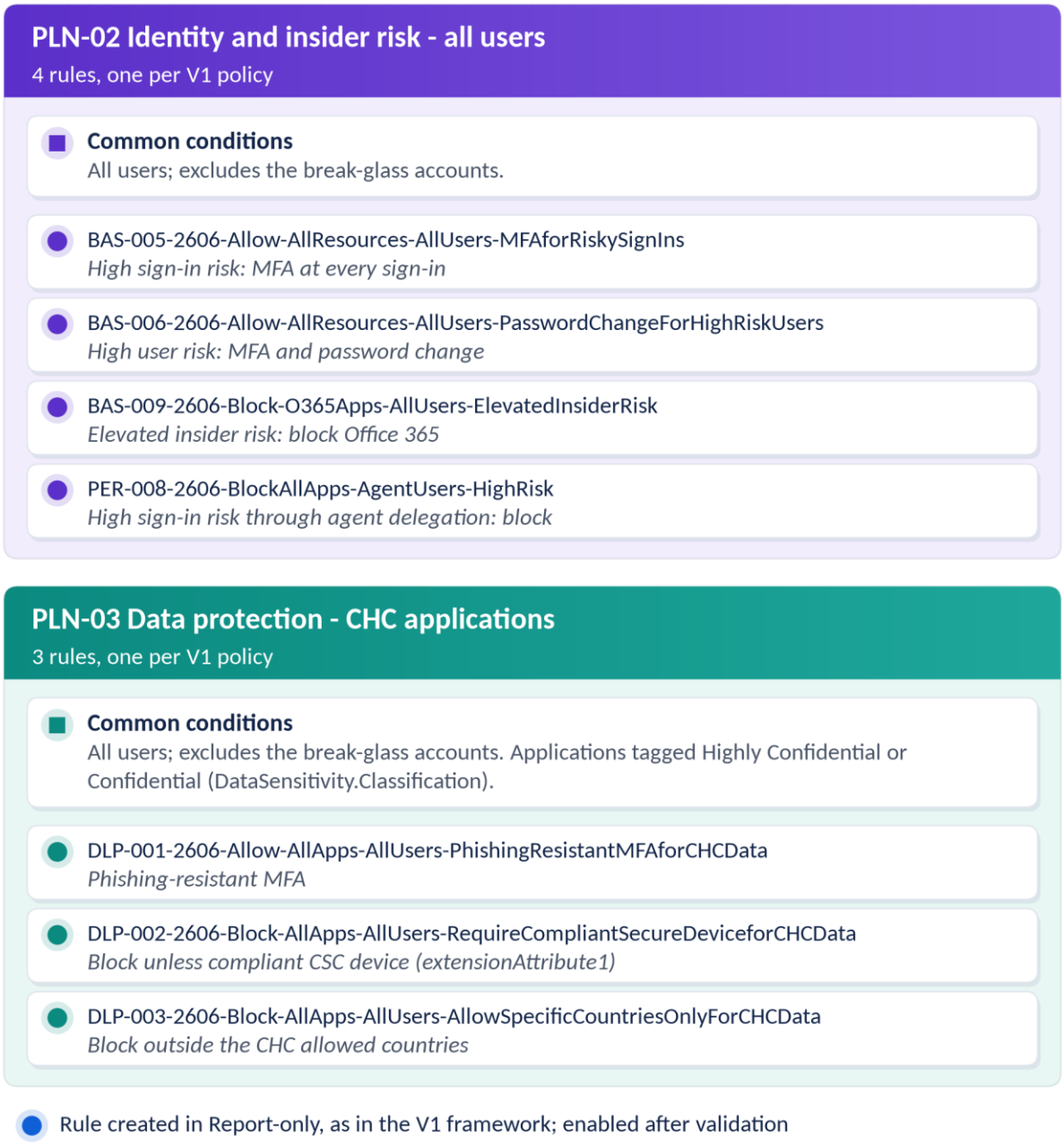


Figure 3b: PLN-02 Identity and insider risk (four rules) and PLN-03 Data protection for CHC applications (three rules). PLN-03 shares the application filter for classified applications across all its rules.

PLN-02 Rules

Rule	Local Conditions (in Addition to Plan Scope)	Controls
BAS-005-2606-Allow-AllResources-AllUsers-MFAforRiskySignIns	All resources; sign-in risk high	Require MFA; session: sign-in frequency every time

Rule	Local Conditions (in Addition to Plan Scope)	Controls
BAS-006-2606-Allow-AllResources-AllUsers-PasswordChangeForHighRiskUsers	All resources; user risk high	Require MFA and password change (AND)
BAS-009-2606-Block-O365Apps-AllUsers-ElevatedInsiderRisk	Office 365; insider risk elevated (Microsoft Purview Adaptive Protection)	Block
PER-008-2606-BlockAllApps-AgentUsers-HighRisk	All resources; sign-in risk high; agent users (preview condition)	Block. If the agents condition is not available in the tenant, the rule is created without it.

PLN-03 Rules

Rule	Local Conditions (in Addition to Plan Scope)	Controls
DLP-001-2606-Allow-AllApps-AllUsers-PhishingResistantMFAforCHCData	None	Authentication strength: phishing-resistant MFA
DLP-002-2606-Block-AllApps-AllUsers-RequireCompliantSecureDeviceforCHCData	Device filter excludes compliant devices with extensionAttribute1 = "CSC"	Block
DLP-003-2606-Block-AllApps-AllUsers-AllowSpecificCountriesOnlyForCHCData	All locations except named location "Countries allowed for CHC data access"	Block

PLN-04 Privileged Roles

PLN-04-2606-PrivilegedRoles applies location, risk and device controls to administrators. The plan scope is the set of 42 privileged directory roles, with break-glass accounts excluded.

PLN-05 Privileged Access Workstations

PLN-05-2606-PrivilegedAccessWorkstations requires phishing-resistant MFA and privileged access workstation (PAW) devices for administrators. Its scope combines the 42 privileged roles with the secure workstation group PAW-Global-Users and covers all applications, again excluding break-glass accounts.

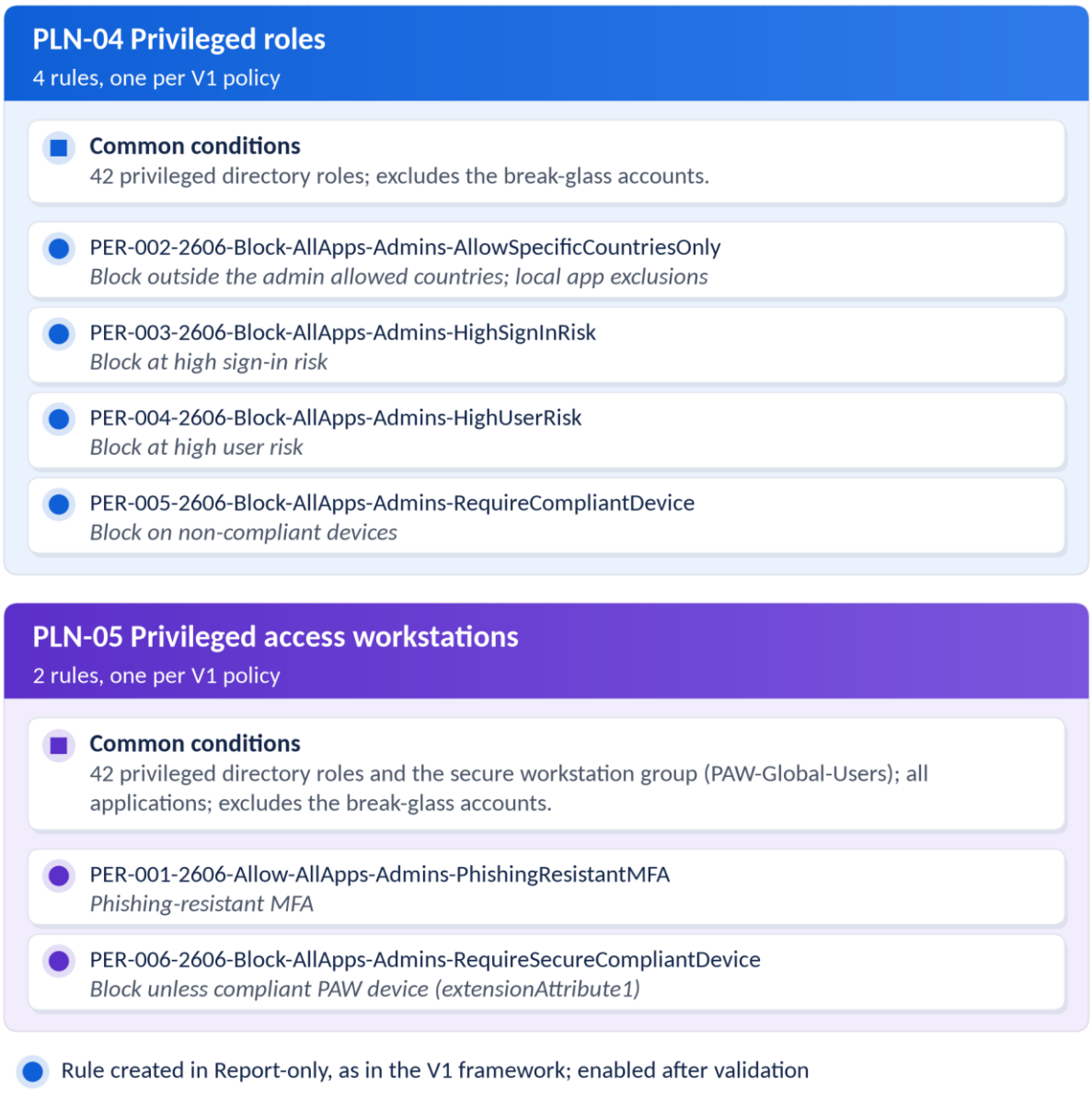


Figure 3c: PLN-04 Privileged roles (four rules) and PLN-05 Privileged access workstations (two rules). PLN-05 adds the secure workstation group to the privileged-role scope.

PLN-04 Rules

Rule	Local Conditions (in Addition to Plan Scope)	Controls
PER-002-2606-Block-AllApps-Admins-	All locations except "Countries allowed for admin access"; excludes	Block

Rule	Local Conditions (in Addition to Plan Scope)	Controls
AllowSpecificCountriesOnly	Azure Virtual Desktop, Device Registration Service, Intune Enrollment and Windows Hello for Business apps where present in the tenant	
PER-003-2606-Block-AllApps-Admins-HighSignInRisk	Sign-in risk high	Block
PER-004-2606-Block-AllApps-Admins-HighUserRisk	User risk high	Block
PER-005-2606-Block-AllApps-Admins-RequireCompliantDevice	Device filter excludes compliant devices	Block

PLN-05 Rules

Rule	Local Conditions (in Addition to Plan Scope)	Controls
PER-001-2606-Allow-AllApps-Admins-PhishingResistantMFA	None	Authentication strength: phishing-resistant MFA
PER-006-2606-Block-AllApps-Admins-RequireSecureCompliantDevice	Device filter excludes compliant devices with extensionAttribute1 = "PAW"	Block

PLN-06 Guest and External Access

PLN-06-2606-GuestAndExternalAccess sets limits for guests and external users. The plan scope is guests and external users, with break-glass accounts excluded.

PLN-07 Workload Identities

PLN-07-2606-WorkloadIdentities targets service principals owned by the tenant rather than users and applies a risk-based block. It requires Microsoft Entra Workload ID Premium.

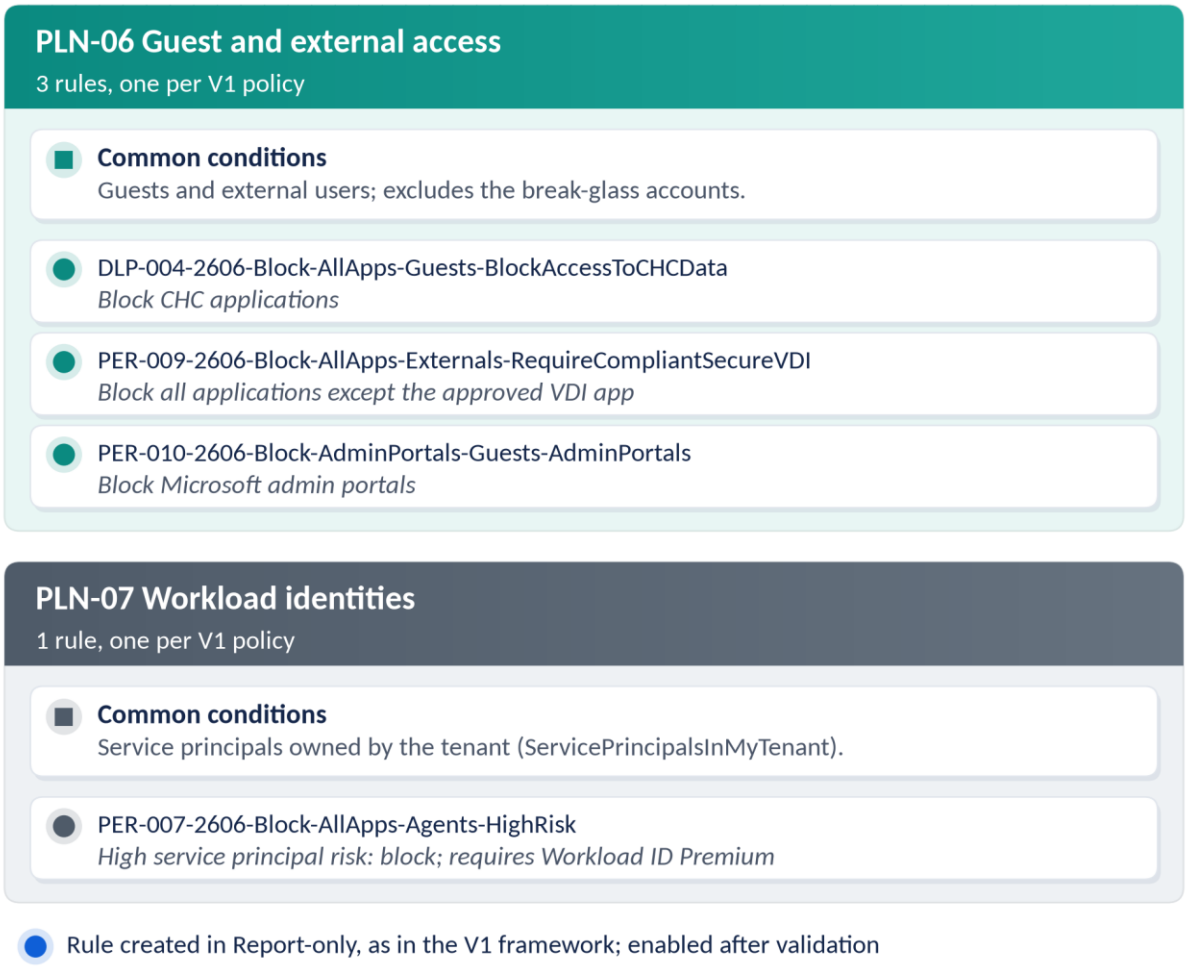


Figure 3d: PLN-06 Guest and external access (three rules) and PLN-07 Workload identities (one rule). PLN-07 targets service principals rather than users and needs Microsoft Entra Workload ID Premium.

PLN-06 Rules

Rule	Local Conditions (in Addition to Plan Scope)	Controls
DLP-004-2606-Block-AllApps-Guests-BlockAccessToCHCData	Applications with the CHC classification filter	Block
PER-009-2606-Block-AllApps-Externals-RequireCompliantSecureVDI	All applications except the approved VDI application (Azure Virtual Desktop)	Block
PER-010-2606-Block-AdminPortals-Guests-	Microsoft Admin Portals	Block

AdminPortals		

PLN-07 Rules

Rule	Local Conditions (in Addition to Plan Scope)	Controls
PER-007-2606-Block-AllApps-Agents-HighRisk	Service principal risk high	Block. Requires Workload ID Premium; skipped with a warning if the licence is missing.

Script Documentation Import-CAPolicyFrameworkV2-PolicyPlans.ps1

Import-CAPolicyFrameworkV2-PolicyPlans.ps1 turns the mapping in this document into a deployment. It is the V2 counterpart of Import-CAPolicyFrameworkV2.ps1, which deploys the 26 framework policies as classic V1 policies. Instead of creating separate policies, the script groups the same 26 policies into Conditional Access V2 policy plans through Microsoft Graph beta, without consolidating or changing the intent of any policy.

In the tenant, the script creates the seven plans PLN-01-2606-… to PLN-07-2606-… with their shared conditions, and adds the 26 rules to them as described in the Plan-by-Plan Detail section. Each rule keeps the name of its V1 policy and, by default, is created in Report-only so its results can be compared with the V1 policy. The script also resolves or creates the two named locations that the rules use. It does not change or delete any existing V1 policy, so both sets can run side by side during migration.

The script requires PowerShell 7 and the Microsoft.Graph.Authentication module. It connects with Policy.ReadWrite.ConditionalAccess plus the read scopes needed for its lookups of applications, groups, users and directory objects.

Parameters

Parameter	Description
-BreakGlassUpn	Up to three break-glass UPNs. If omitted, break-glass accounts are detected and confirmed interactively.
-RuleState	State for the created rules: enabledForReportingButNotEnforced (default), enabled or disabled.
-NoSharedConditions	Writes all conditions onto every rule instead of using plan shared conditions. Use as a fallback if shared conditions are rejected.
-ExportPath	Writes the plan JSON bodies to the given folder for review.
-ExportOnly	Exports the bodies with placeholder IDs and makes no changes in the tenant.
-WhatIf	Shows what would be created without creating it.

Script Flow

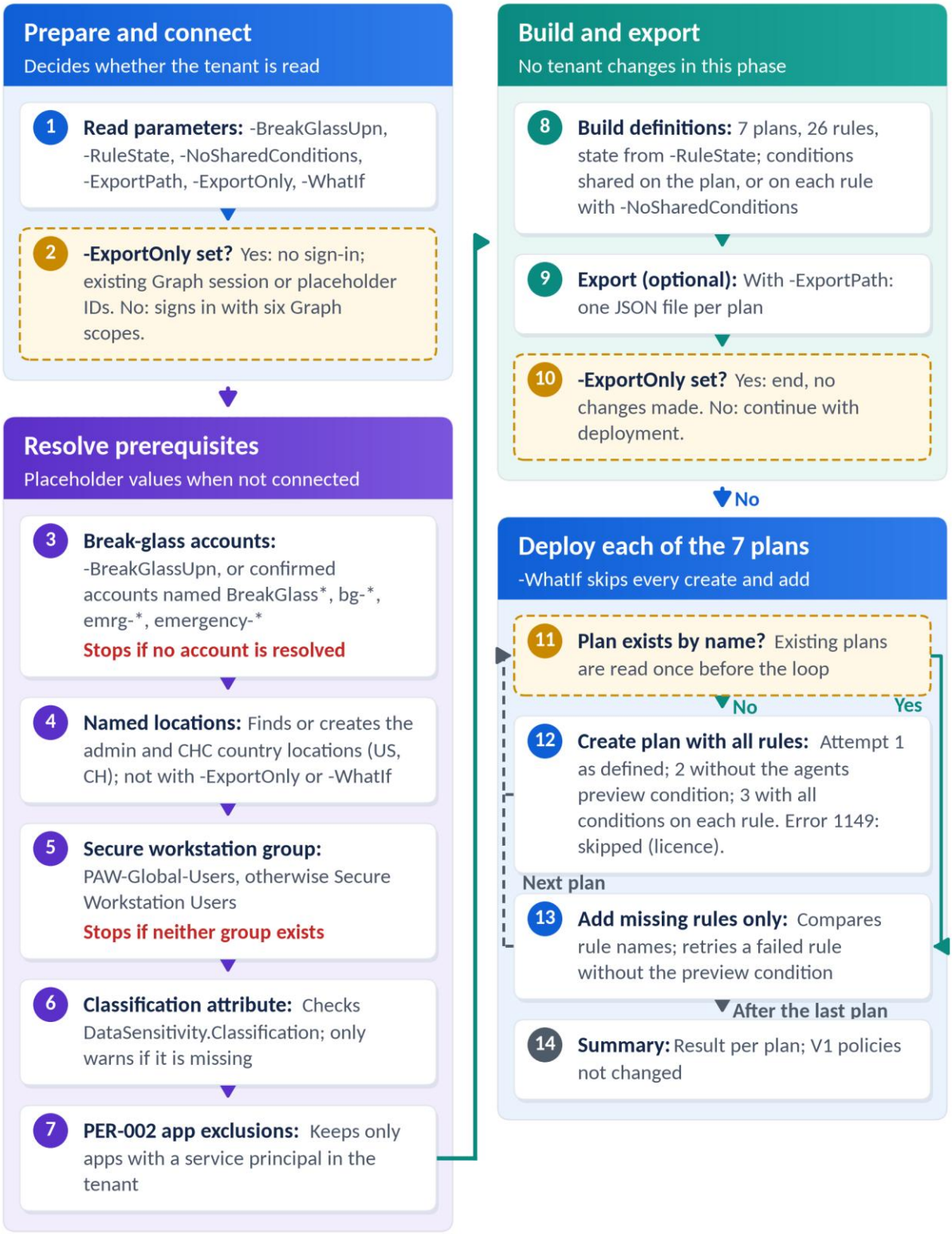


Figure 4: Deployment script flow. The script reads its parameters, signs in unless -ExportOnly is set, and resolves the break-glass accounts, named locations, secure workstation group, classification attribute and PER-002 application exclusions; it stops if no break-glass account or secure workstation group is found. It then builds and optionally exports the 7 plan definitions. Unless -

ExportOnly is set, it creates each missing plan with all its rules (with up to three attempts) or adds only the missing rules to an existing plan, and finishes with a summary. V1 policies are never changed.

- Resolves or creates the two named locations; the allowed countries default to United States and Switzerland.
- Requires the secure workstation group to exist and warns if the DataSensitivity custom security attribute is missing.
- Adds application exclusions only for service principals that exist in the tenant.
- Is idempotent: existing plans are matched by name and kept, and only missing rules are added.
- Retries plan creation without the preview agents condition and, if needed, with flattened conditions.
- Skips PER-007 when Workload ID Premium is not available.
- Never changes or deletes V1 policies.

Examples

Create the plans with two named break-glass accounts:

```
.\Import-CAPolicyFrameworkV2-PolicyPlans.ps1 -BreakGlassUpn
'BreakGlass1@contoso.com','BreakGlass2@contoso.com'
```

Export the plan bodies for review without changing the tenant:

```
.\Import-CAPolicyFrameworkV2-PolicyPlans.ps1 -ExportOnly -ExportPath .\plans
```

Preview creation with all rules disabled:

```
.\Import-CAPolicyFrameworkV2-PolicyPlans.ps1 -RuleState disabled -WhatIf
```

Prerequisites

- Microsoft Entra ID P1, and P2 for the risk-based rules BAS-005, BAS-006, PER-003, PER-004 and PER-008.
- Microsoft Purview Insider Risk Management with Adaptive Protection for BAS-009.
- Microsoft Entra Workload ID Premium for PER-007.
- The custom security attribute set DataSensitivity with the attribute Classification assigned to applications.
- Device extensionAttribute1 values CSC and PAW on the corresponding devices.
- The PAW-Global-Users group.
- Break-glass accounts.

Coexistence and Migration

Because V1 policies and V2 rules are both evaluated, running both in enforced state doubles the requirements a sign-in must satisfy but does not weaken security. The recommended path is to deploy the plans in Report-only (or disabled), compare the Report-only outcome of each rule with its V1 counterpart, enable the rules family by family, and then disable the matching V1 policy, keeping it for rollback for an agreed period.

The script creates rules in Report-only by default. To start with rules switched off, run it with -RuleState disabled (step 4 in Figure 4).

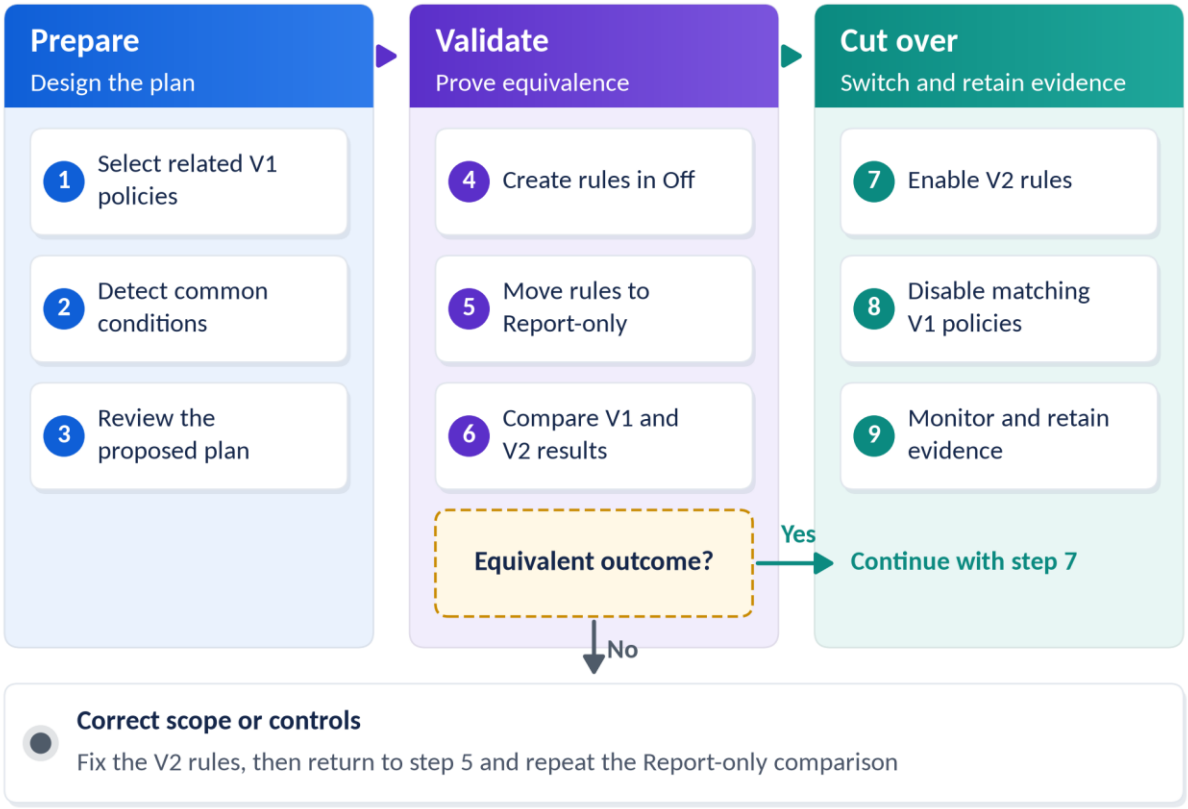


Figure 5: Migration workflow. Plans are prepared and created alongside the V1 policies, validated in Report-only against the V1 results, and cut over plan by plan; any deviation is corrected before the comparison is repeated.

The suggested cut-over order is:

- PLN-01 and PLN-06 first, as they are broad and low in complexity.
- PLN-02 and PLN-03 next.
- PLN-04 and PLN-05 after that. These carry a risk of administrator lockout, so test them only after break-glass access has been verified.
- PLN-07 last.

Considerations and Limits

- Policy plans use the Microsoft Graph beta API, and policy plans and the agent condition are preview features, so behaviour may change.
- Break-glass accounts must be excluded at plan level and monitored.
- The V1 script contains one naming discrepancy. Its existence check for DLP-004 uses the name DLP-004-2606-Block-AllApps-Guests-AccessToCHCData, while the policy is created as DLP-004-2606-Block-AllApps-Guests-BlockAccessToCHCData, so re-running the V1 script can create a duplicate. The V2 script uses the created name.
- Test in a non-production tenant first.

Disclaimer

This document and the companion script Import-CAPolicyFrameworkV2-PolicyPlans.ps1 are provided as guidance and as-is, without warranty of any kind, either express or implied, including warranties of merchantability, fitness for a particular purpose or non-infringement. You use the document and the script entirely at your own risk. The authors and publishers accept no liability for any loss, damage or disruption, including administrator lockout or unintended access changes, arising from their use. Validate all configurations and test the script in a non-production tenant before use. Microsoft Graph beta APIs are not supported for production use.